

Pen Testing: Attacking a Vulnerable Metasploitable Machine



The Metasploitable framework is an open source framework created by the Rapid7 Metasploit team. It is used by many cybercriminals and ethical hackers to study different vulnerabilities on servers and networks. It is easily customisable and is compatible with most operating systems. Metasploitable is used by penetration testers to study the weak spots of a network.

In this article we will see how we can attack the Metasploitable framework. In this attack we will be able to access the file system of a vulnerable Metasploitable machine.

You can download the .iso file from <https://www.vulnhub.com/entry/metasploitable-2,29/> and run it using any virtualisation software like VMware or VirtualBox.

Now open your Metasploitable machine and enter the user name and password – ‘msfadmin’ in both cases. Then use the command `ifconfig` to find the IP address of the Metasploitable machine, as shown in Figure 1.

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:b4:25:4b
          inet addr:192.168.2.209  Bcast:192.168.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:feb4:254b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:116 errors:0 dropped:0 overruns:0 frame:0
          TX packets:47 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:12660 (12.3 KB)  TX bytes:5434 (5.3 KB)
          Base address:0xd000  Memory:f0000000-f0020000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:93 errors:0 dropped:0 overruns:0 frame:0
          TX packets:93 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19485 (19.0 KB)  TX bytes:19485 (19.0 KB)
```

Figure 1: `ifconfig` on the Metasploitable machine

Now open a Kali Linux terminal and run the following command to find out all the vulnerable services available in Metasploitable. Run the command:

`nmap -T4 -sV <metasploitable IP address>`

```
root@kali:~# nmap -T4 -sV 192.168.2.209
Starting Nmap 7.80 ( https://nmap.org ) at 2021-04-05 20:58 IST
Nmap scan report for 192.168.2.209
Host is up (0.0001s latency).
Not shown: 978 closed ports
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          postfix smtpd
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi       GNU Classpath gmrregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  x11           (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
1 service unrecognized despite returning data. If you know the service/version, please submit
SF-Port514-TCP:V=7.80X1=7XD=4/SXTime=60682C87AP=x86_64-pc-linux-gnuXR(NULL
SF:28,"\\x01Couldn't\\x20get\\x20address\\x20for\\x20your\\x20host\\x20\\(kali\\
SF:n");
MAC Address: 08:00:27:B4:25:4B (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CP
```

Figure 2: Vulnerabilities in Metasploitable